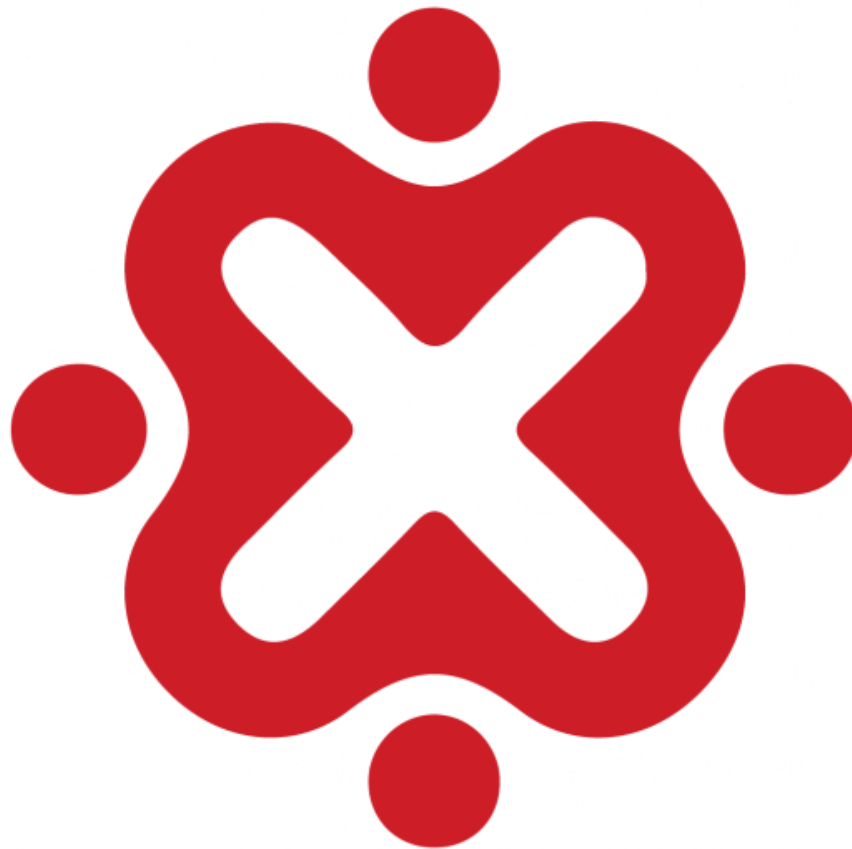


Tugas Sesi 3 - Minggu 2 : **Reconnaissance & Enumeration Target Bug Bounty**



ID-Networkers
Indonesian IT Expert Factory

Oleh: Sofiyanatul Munawaroh



Pendahuluan

Reconnaissance dan enumeration merupakan tahap awal yang penting dalam penetration testing maupun bug bounty. Pada tahap ini dilakukan pengumpulan informasi mengenai target untuk mengidentifikasi aset yang terekspos, struktur sistem, serta potensi permukaan serangan (attack surface).

Proses ini membantu penguji memahami lingkungan target secara menyeluruh sebelum melakukan analisis lebih lanjut. Tanpa reconnaissance yang baik, pengujian keamanan berisiko tidak terarah dan kurang efektif. Oleh karena itu, tahap ini menjadi fondasi dalam proses identifikasi dan evaluasi potensi risiko keamanan suatu sistem.

Tujuan

Tujuan dari kegiatan ini adalah melakukan pemetaan aset (asset mapping) dan identifikasi teknologi yang digunakan oleh target guna memahami permukaan serangan (attack surface) yang tersedia. Melalui proses tersebut, diharapkan dapat ditemukan potensi celah keamanan atau eksposur informasi yang dapat dianalisis lebih lanjut dalam pengujian keamanan.

Profil Target (Bug Bounty Program)

- **Platform:** Bugcrowd
- **Nama Program:** Luno
- **Target Domain:** luno.com (beserta subdomain yang termasuk dalam scope program)
- **Cakupan (Scope):**

Berdasarkan informasi pada halaman program Bugcrowd, target yang termasuk dalam ruang lingkup pengujian meliputi beberapa domain staging berikut:

- *.staging.luno.com
- *staging.luno.com.ng
- https://api.staging.luno.com/
- https://app.staging.luno.com/



Tahap Reconnaissance & Enumeration

A. Web Stack Identification

- **Metode:**

Identifikasi web stack dilakukan menggunakan teknik passive reconnaissance dengan menganalisis HTTP response header melalui perintah:

```
curl -I https://www.staging.luno.com
```

Metode ini bertujuan untuk mengumpulkan informasi teknis terkait infrastruktur dan konfigurasi server tanpa melakukan interaksi eksploitasi terhadap sistem target.

- **Informasi yang Dicari:**

Pada tahap ini, informasi yang dikumpulkan meliputi:

- Web server atau origin server
- Penggunaan CDN atau Web Application Firewall (WAF)
- Versi protokol HTTP
- Security headers yang diterapkan
- Kebijakan indexing (robots directive)
- Indikasi teknologi frontend atau dependensi eksternal

- **Dokumentasi:**

Berdasarkan hasil HTTP response header, diperoleh informasi sebagai berikut:

- a. Status Protokol
 - HTTP/2 aktif
 - Status response: 200 OK
- b. Infrastruktur
 - server: cloud-flare
 - cf-ray header terdeteksi
 - cf-cache-status: DYNAMIC
- c. Security Headers
 - content-security-policy
 - x-content-type-options: nosniff
 - strict-transport-security
 - cross-origin-opener-policy
 - permissions-policy
 - Referrer-policy



- x-robots-tag: noindex, nofollow
- d. Cookie yang Terdeteksi
- cf_country
 - __cf_bm

B. Registrasi Domain (WHOIS)

- **Metode:**

Melakukan enumerasi informasi registrasi domain menggunakan protokol WHOIS untuk memperoleh data administratif dan teknis domain.

Tools yang digunakan: whois (CLI)

Perintah yang dijalankan:

```
whois luno.com
```

- **Informasi yang Dicari:**

- Nama domain terdaftar
- Registrar yang digunakan
- Tanggal pembuatan domain (Creation Date)
- Tanggal kedaluwarsa domain (Expiry Date)
- Status domain
- Name Server yang digunakan
- Status DNSSEC

- **Dokumentasi Hasil**

Informasi Umum Domain

- Domain Name: LUNO.COM
- Registry Domain ID: 53760480_DOMAIN_COM-VRSN
- Registrar: Gandi SAS
- Registrar IANA ID: 81

Timeline Registrasi

- Creation Date: 2001-01-24
- Updated Date: 2025-12-24
- Expiry Date: 2027-01-24

Status Domain

- clientTransferProhibited

Name Server

- BARBARA.NS.CLOUDFLARE.COM
- PABLO.NS.CLOUDFLARE.COM



DNS Security

→ DNSSEC: signedDelegation

C. DNS Enumeration

- **Metode:**

Melakukan enumerasi DNS menggunakan tools dig untuk memperoleh informasi record domain.

Jenis record yang diuji:

- A Record
- NS Record
- MX Record
- TXT Record
- Zone Transfer (AXFR)

Tools yang digunakan:

- dig (DNS lookup utility)

Perintah yang dijalankan:

```
dig luno.com A
dig luno.com NS
dig luno.com MX
dig luno.com TXT
dig axfr luno.com @barbara.ns.cloudflare.com
dig axfr luno.com @pablo.ns.cloudflare.com
```

- **Dokumentasi Hasil:**

1. A Record

luno.com.	300	IN	A	172.64.153.121
luno.com.	300	IN	A	104.18.34.135

2. NS Record

luno.com.	86398	IN	NS
barbara.ns.cloudflare.com.			
luno.com.	86398	IN	NS
pablo.ns.cloudflare.com.			

3. MX Record

luno.com.	300	IN	MX	1
aspmx.l.google.com.				
luno.com.	300	IN	MX	10
aspmx2.googlemail.com.				



luno.com.	300	IN	MX	10
aspmx3.googlemail.com.				
luno.com.	300	IN	MX	5
alt1.aspmx.l.google.com.				
luno.com.	300	IN	MX	5
alt2.aspmx.l.google.com.				

4. TXT Record

Total record terdeteksi: 27 TXT record.

Beberapa record yang teridentifikasi:

```
google-site-verification
v=spf1 include:amazonses.com include:_spf.google.com
include:_spf.atlassian.net include:spf.sendinblue.com
include:mail.zendesk.com -all
facebook-domain-verification
slack-domain-verification
atlassian-domain-verification
twilio-domain-verification
apple-domain-verification
```

5. Zone Transfer (AXFR)

Percobaan transfer zona terhadap name server:

```
Transfer failed.
```

D. Subdomain Enumeration

- **Metode:**

Melakukan enumerasi subdomain menggunakan teknik passive reconnaissance dengan tools subfinder.

Tools yang digunakan:

- Subfinder v2.12.0 (ProjectDiscovery)

Perintah yang dijalankan:

```
subfinder -d luno.com
```

- **Dokumentasi:**

- Target domain: luno.com
- Total subdomain ditemukan: 129 subdomain
- Waktu eksekusi: 41.926 detik

Berikut sebagian daftar subdomain yang teridentifikasi:



```
www.luno.com
api.luno.com
app.luno.com
staging.luno.com
dev.luno.com
sandbox.luno.com
test.luno.com
mobileapi.luno.com
trade.luno.com
console.luno.com
status.luno.com
monitoring.luno.com
research.luno.com
invest.luno.com
crypto.luno.com
careers.luno.com
groups.luno.com
one.luno.com
discover.luno.com
indonesia.luno.com
reporting.indonesia.luno.com
api.staging.luno.com
app.staging.luno.com
trade.staging.luno.com
mobileapi.staging.luno.com
promos.luno.com
promos.staging.luno.com
guide.luno.com
guide-staging.luno.com
sftp.luno.com
ws.luno.com
ws2.luno.com
ajax.luno.com
ajax.staging.luno.com
```

(Total lengkap: 129 subdomain – output penuh dilampirkan pada Lampiran 5)

E. Fuzzing & Directory Discovery

- **Metode:**

Melakukan enumerasi direktori dan file menggunakan beberapa pendekatan:

1. Pemeriksaan file robots.txt
2. Pemeriksaan sitemap.xml
3. Directory fuzzing menggunakan wordlist umum

Tools yang digunakan:

- Curl



- ffuf (v2.1.0-dev)
- Wordlist: /usr/share/wordlists/dirb/common.txt

- **Informasi yang Dicari:**

- Keberadaan file robots.txt
- Keberadaan sitemap.xml
- Daftar URL publik dari sitemap
- Direktori atau endpoint yang dapat diakses publik
- Response status code (200, 301, 302)

- **Dokumentasi:**

1. Robots.txt

Perintah:

```
curl https://www.luno.com/robots.txt
curl https://www.staging.luno.com/robots.txt
```

Hasil:

```
User-agent: *
Allow: /

Sitemap: https://www.luno.com/sitemap.xml
```

2. Sitemap.xml

Perintah:

```
curl https://www.luno.com/sitemap.xml | head -n 50
```

Hasil (ringkasan):

```
<sitemapindex>
  https://www.luno.com/sitemap_en-ZA.xml
  https://www.luno.com/sitemap_en-GB.xml
  https://www.luno.com/sitemap_ms-MY.xml
  https://www.luno.com/sitemap_en-MY.xml
  https://www.luno.com/sitemap_id-ID.xml
  https://www.luno.com/sitemap_en-ID.xml
  https://www.luno.com/sitemap_en-AU.xml
  https://www.luno.com/sitemap_en-UG.xml
  https://www.luno.com/sitemap_en-KE.xml
  https://www.luno.com/sitemap_en-NG.xml
</sitemapindex>
```

Hasil ini menunjukkan adanya sitemap berbasis regional/language.

3. Directory Fuzzing (FFUF)



Perintah:

```
ffuf -u https://www.luno.com/FUZZ -w  
/usr/share/wordlists/dirb/common.txt -mc 200,301,302 -t  
20
```

Konfigurasi:

- Method: GET
- Threads: 20
- Wordlist entries: 4614
- Filter status code: 200, 301, 302

Hasil:

```
:: Progress: [4614/4614]  
:: Errors: 0
```

Dari hasil tersebut, tidak ditemukan direktori tambahan dengan status code 200, 301, atau 302 berdasarkan wordlist yang digunakan.

F. Wayback Machine

- **Metode:**

Melakukan enumerasi arsip URL historis menggunakan tools waybackurls untuk mengidentifikasi endpoint lama dan parameter yang pernah digunakan.

Tahapan yang dilakukan:

1. Mengambil seluruh URL historis dari Wayback Machine
2. Menghitung total URL
3. Mengekstrak URL yang memiliki parameter (=)
4. Membersihkan parameter tracking (utm, fbclid, dll.)
5. Memfilter parameter yang berpotensi sensitif
6. Normalisasi parameter menjadi format fuzzing
7. Analisis frekuensi parameter

Perintah yang dijalankan:

```
waybackurls luno.com > wayback.txt  
wc -l wayback.txt  
  
cat wayback.txt | grep "=" | sort -u > params.txt  
wc -l params.txt  
  
grep -Ev "utm_|fbclid|gclid|ref=|source=|campaign="   
params.txt > clean1.txt  
wc -l clean1.txt
```



```
grep -Ei  
"id=|user=|account=|token=|redirect=|url=|next=|return=|fi  
le=|download=|callback=|email=|reset=" clean1.txt >  
interesting.txt  
wc -l interesting.txt  
  
cat interesting.txt | sed 's/=[^&]*/=FUZZ/g' | sort -u >  
normalized.txt  
wc -l normalized.txt
```

- **Temuan:**

1. Total URL Historis
 - Total URL dari Wayback Machine: 42.487 URL
2. URL dengan Paramater
 - URL unik yang memiliki parameter: 5.937
 - Setelah pembersihan tracking parameter: 5.072
 - Parameter yang dianggap menarik: 1.038
 - Endpoint ter-normalisasi untuk fuzzing: 226
3. Parameter Paling Sering Muncul

Frekuensi	Parameter
49	gh_jid
36	ticket_form_id
36	id
16	redirect
15	url
10	token
10	category_id
7	source_account_id
6	lid
4	irelickid
3	state



2	email
2	login_token
1	account_id
1	payment_id

4. Endpoint yang Paling Sering Mengandung Parameter

Frekuensi	Endpoint
15	https://guide.luno.com/hc/en-gb/requests/new
9	https://guide.luno.com/hc/ms-my/requests/new
9	https://guide.luno.com/hc/id/requests/new
6	https://guide.luno.com/hc/fr/requests/new
4	https://www.luno.com/wallet/transfer
3	https://www.luno.com/wallet/buy
3	https://www.luno.com/help/en/tickets/new
2	https://www.luno.com/wallet/beneficiaries/add
2	https://www.luno.com/signup

G. Dorking

- **Metode:**

Pengumpulan informasi menggunakan teknik Google Dorking untuk mengidentifikasi:

- Subdomain yang terindeks mesin pencari
- File sensitif (PDF, doc, dll.)
- Halaman login
- Parameter dalam URL
- Error/debug page
- Endpoint API
- Potensi kebocoran data

Teknik ini memanfaatkan operator pencarian seperti:



```
site:  
filetype:  
inurl:  
  
intitle:  
intext:
```

- **Temuan:**

1. Subdomain yang Terindeks

Query:

```
site:luno.com
```

Subdomain yang muncul di hasil pencarian:

- status.luno.com
- careers.luno.com
- framer.luno.com
- discover.luno.com
- www.luno.com

Beberapa subdomain publik terindeks dengan baik. Tidak ditemukan subdomain internal sensitif yang terekspos melalui indexing Google.

2. File Sensitif

Query:

```
site:luno.com filetype:pdf
```

File PDF publik ditemukan (dokumentasi, panduan, dll).

Tidak ditemukan file konfigurasi atau file internal sensitif yang terindeks secara langsung.

3. Halaman Login

Query:

```
site:luno.com inurl:login
```

Halaman login publik ditemukan (normal exposure).

Tidak ditemukan halaman admin tersembunyi yang terindeks.

4. Parameter Terindeks

Query:

```
site:luno.com inurl:=
```

Beberapa URL dengan parameter terindeks, namun sebagian besar adalah halaman bantuan atau tracking parameter.



5. Error / Debug Page

Query:

```
site:luno.com intext:"internal server error"  
site:luno.com intext:"exception"  
site:luno.com intitle:"index of"
```

Tidak ditemukan halaman debug, stack trace, atau directory listing yang terindeks secara publik.

6. API Exposure

Query:

```
site:luno.com inurl:api
```

Endpoint API publik ditemukan (normal behavior).

Tidak ditemukan dokumentasi API internal atau key yang terekspos.

Analisis Temuan

A. Web Stack Identification

Ringkasan Temuan

- Menggunakan Cloudflare sebagai DNS dan proteksi layer
- DNSSEC aktif (signed delegation)
- Server berada di belakang reverse proxy
- Tidak ada informasi backend langsung terekspos

Analisis Keamanan

Penggunaan Cloudflare menunjukkan bahwa sistem telah menerapkan:

- Web Application Firewall (WAF)
- DDoS protection
- IP masking (origin server tidak langsung terlihat)
- TLS termination yang dikelola dengan baik

DNSSEC yang aktif menunjukkan mitigasi terhadap:

- DNS spoofing
- Cache poisoning attack

Risk Level: Low

Tidak ditemukan misconfiguration pada layer ini.



B. Registrasi Domain (WHOIS)

Ringkasan Temuan

- Registrar: Gandi SAS
- Domain aktif sejak 2001
- DNSSEC enabled
- Nameserver: Cloudflare

Analisis Keamanan

Domain lama (est. 2001) menunjukkan:

- Reputasi dan stabilitas organisasi
- Bukan domain baru yang mencurigakan

Tidak ditemukan:

- Email admin terbuka
- Informasi personal terekspos
- Data sensitif pada WHOIS

Risk Level: Low

C. Fuzzing & Directory Discovery

Ringkasan Temuan

- robots.txt mengizinkan crawling
- Sitemap tersedia
- ffuf tidak menemukan hidden directory signifikan

Analisis Keamanan

robots.txt tidak menyembunyikan direktori sensitif.

Tidak ditemukan:

- /admin
- /backup
- /dev
- /config
- Directory listing terbuka

Hal ini menunjukkan:

- Tidak ada misconfiguration umum
- Tidak ada endpoint tersembunyi yang mudah ditebak
- Struktur aplikasi relatif tertata dan minim exposure



Risk Level: Low

D. Wayback Machine Enumeration

Ringkasan Temuan

- 42.487 URL historis
- 5.937 parameter unik
- 1.038 parameter dianggap menarik
- 226 endpoint ternormalisasi
- Parameter dominan: id, redirect, url, token

Analisis Keamanan

Parameter yang paling sering muncul:

- id
- redirect
- url
- token
- email

Secara teori parameter ini berpotensi menyebabkan:

- IDOR (jika id tidak divalidasi)
- Open Redirect (redirect/url)
- Token leakage
- Account manipulation

Namun:

- Tidak ditemukan bukti eksploitasi
- Tidak ada indikasi parameter sensitif aktif tanpa autentikasi
- Tidak ditemukan kredensial hardcoded

Jumlah URL historis besar menunjukkan platform berkembang lama, tetapi tidak ada endpoint lama yang tampak rentan secara langsung.

Risk Level: Medium (Potential Attack Surface)

Hal ini bukan karena ditemukannya celah, tetapi karena banyak parameter yang berpotensi diuji lebih lanjut.



E. Google Dorking

Ringkasan Temuan

- Subdomain publik terindeks
- Tidak ada file konfigurasi sensitif
- Tidak ada kredensial terindeks
- Tidak directory listing

Analisis Keamanan

Tidak ditemukan:

- .env file
- config.php
- backup.sql
- exposed API key
- error stack trace

Hal ini menunjukkan:

- Manajemen indexing baik
- Tidak ada exposure via search engine
- Tidak ada sensitive leak via Google cache

Risk Level: Low

Penutup

Berdasarkan tahapan reconnaissance dan enumeration terhadap domain luno.com, tidak ditemukan indikasi misconfiguration kritikal maupun kebocoran informasi sensitif yang terekspos secara publik. Infrastruktur berada di belakang Cloudflare dengan DNSSEC aktif, serta tidak ditemukan zone transfer terbuka, directory listing, file sensitif terindeks, maupun environment development yang terekspos.

Meskipun ditemukan sejumlah parameter aplikasi dari hasil enumerasi historis, tidak terdapat bukti kerentanan aktif pada tahap pengujian pasif ini. Secara keseluruhan, tingkat risiko pada fase reconnaissance tergolong rendah, dengan permukaan serangan yang masih dalam batas wajar untuk platform berskala besar.

Pengujian lanjutan pada tahap active testing tetap diperlukan untuk memperoleh evaluasi keamanan yang lebih komprehensif.



Lampiran

Lampiran 1 - Halaman Program Bugcrowd (Luno)

Web targets ✓ In scope

P1

\$2500 – \$3000

P2

\$1500 – \$1800

P3

\$500 – \$650

P4

\$100 – \$200

Please ensure to prefix the endpoints to <https://staging.luno.com> when testing. The OpenAPI specification is available for download from our documentation. You can import this into your tool of choice i.e. Postman.

[OpenAPI Specification Download.](#)

🌐 *.staging.luno.com/

TypeScript Go Website Testing +1

4

🔗

🌐 *staging.luno.com.ng/

TypeScript Go Angular

0

🔗

🔗 https://api.staging.luno.com/

API Testing nginx Go

0

🔗

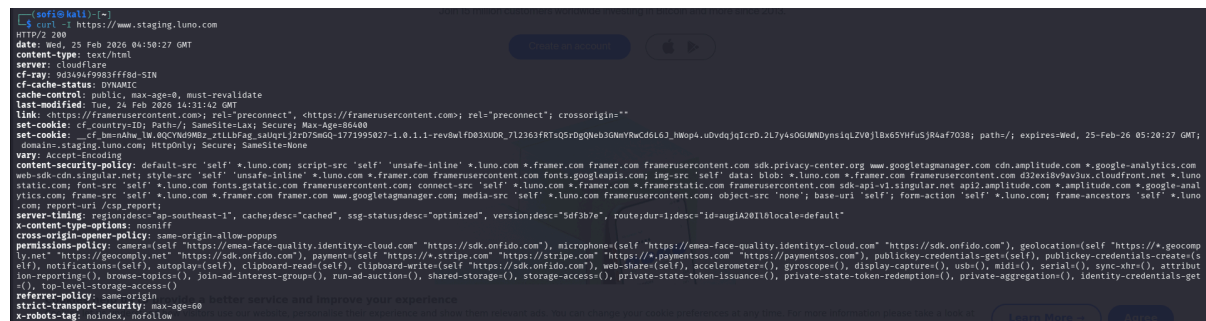
🌐 https://app.staging.luno.com/

TypeScript Go Website Testing +1

0

🔗

Lampiran 2.1 - Screenshot Webstack Identification



Lampiran 2.2 - Raw Output

```
curl -I https://www.staging.luno.com
HTTP/2 200
date: Wed, 25 Feb 2026 04:50:27 GMT
content-type: text/html
server: cloudflare
cf-ray: 9d3494f9983fff8d-SIN
cf-cache-status: DYNAMIC
cache-control: public, max-age=0, must-revalidate
last-modified: Tue, 24 Feb 2026 14:31:42 GMT
link: <https://framerusercontent.com>; rel="preconnect",
<https://framerusercontent.com>; rel="preconnect"; crossorigin=""
```



```
set-cookie:
__cf_bm=nAhw_lW.0QCYNd9MBz_ztLLbFag_saUqrLj2rD7SmGQ-1771995027-1.0.1.1-rev8wlf
D03XUDR_712363fRTsQ5rDgQNeB3GNmYRwCd6L6J_hWop4.uDvdqjqIcrD.2L7y4sOGUWNDynsiqLZ
V0jlBx65YHfuSjR4af7038; path=/; expires=Wed, 25-Feb-26 05:20:27 GMT;
domain=.staging.luno.com; HttpOnly; Secure; SameSite=None
vary: Accept-Encoding
content-security-policy: default-src 'self' *.luno.com; script-src 'self'
'unsafe-inline' *.luno.com *.framer.com framer.com framerusercontent.com
sdk.privacy-center.org www.googletagmanager.com cdn.amplitude.com
*.google-analytics.com web-sdk-cdn.singular.net; style-src 'self'
'unsafe-inline' *.luno.com *.framer.com framerusercontent.com
fonts.googleapis.com; img-src 'self' data: blob: *.luno.com *.framer.com
framerusercontent.com d32exi8v9av3ux.cloudfront.net *.lunostatic.com; font-src
'self' *.luno.com fonts.gstatic.com framerusercontent.com; connect-src 'self'
*.luno.com *.framer.com *.framerstatic.com framerusercontent.com
sdk-api-v1.singular.net api2.amplitude.com *.amplitude.com
*.google-analytics.com; frame-src 'self' *.luno.com *.framer.com framer.com
www.googletagmanager.com; media-src 'self' *.luno.com framerusercontent.com;
object-src 'none'; base-uri 'self'; form-action 'self' *.luno.com;
frame-ancestors 'self' *.luno.com; report-uri /csp_report;
server-timing: region;desc="ap-southeast-1", cache;desc="cached",
ssg-status;desc="optimized", version;desc="5df3b7e",
route;dur=1;desc="id=augia20il&locale=default"
x-content-type-options: nosniff
cross-origin-opener-policy: same-origin-allow-popups
permissions-policy: camera=(self
"https://emea-face-quality.identityx-cloud.com" "https://sdk.onfido.com"),
microphone=(self "https://emea-face-quality.identityx-cloud.com"
"https://sdk.onfido.com"), geolocation=(self "https://*.geocomply.net"
"https://geocomply.net" "https://sdk.onfido.com"), payment=(self
"https://*.stripe.com" "https://stripe.com" "https://*.paymentsos.com"
"https://paymentsos.com"), publickey-credentials-get=(self),
publickey-credentials-create=(self), notifications=(self), autoplay=(self),
clipboard-read=(self), clipboard-write=(self "https://sdk.onfido.com"),
web-share=(self), accelerometer=(), gyroscope=(), display-capture=(), usb=(),
midi=(), serial=(), sync-xhr=(), attribution-reporting=(), browse-topics=(),
join-ad-interest-group=(), run-ad-auction=(), shared-storage=(),
storage-access=(), private-state-token-issuance=(),
private-state-token-redemption=(), private-aggregation=(),
identity-credentials-get=(), top-level-storage-access=()
referrer-policy: same-origin
strict-transport-security: max-age=60
x-robots-tag: noindex, nofollow
```

Lampiran 3 - Screenshot whois



```
➔ whois luno.com
Domain Name: LUNO.COM
Registry Domain ID: 53760480_DOMAIN_COM-VRSN
Registrar WHOIS Server: whois.gandi.net
Registrar URL: http://www.gandi.net
Updated Date: 2025-12-24T09:50:43Z
Creation Date: 2001-01-24T11:38:27Z
Registry Expiry Date: 2027-01-24T11:38:23Z
Registrar: Gandi SAS
Registrar IANA ID: 81
Registrar Abuse Contact Email: abuse@support.gandi.net
Registrar Abuse Contact Phone: +33.170377661
Domain Status: clientTransferProhibited https://icann.org/epp#clientTransferProhibited
Name Server: BARBARA.NS.CLOUDFLARE.COM
Name Server: PABLO.NS.CLOUDFLARE.COM
DNSSEC: signedDelegation
DNSSEC DS Data: 2371 13 2 3AD89F130678E1909DE2E93BF3E052365402E372B74F0A524FEEE2DE8383CBCC
URL of the ICANN Whois Inaccuracy Complaint Form: https://www.icann.org/wicf/
>>> Last update of whois database: 2026-02-25T05:06:53Z <<<
```

Lampiran 4.1 - A Record

```
(sofi@kali)-[~]
$ dig luno.com A

; <<>> DiG 9.20.15-2-Debian <<>> luno.com A
;; global options: +cmd
;; Got answer:
;; ->HEADER<- opcode: QUERY, status: NOERROR, id: 1318
;; flags: qr rd; QUERY: 1, ANSWER: 2, AUTHORITY: 0, ADDITIONAL: 0
;; WARNING: recursion requested but not available

;; QUESTION SECTION:
;luno.com.                IN      A

;; ANSWER SECTION:
luno.com.                 300     IN      A      172.64.153.121
luno.com.                 300     IN      A      104.18.34.135

;; Query time: 123 msec
;; SERVER: 192.168.110.1#53(192.168.110.1) (UDP)
;; WHEN: Wed Feb 25 12:11:23 WIB 2026
;; MSG SIZE rcvd: 58
```

Lampiran 4.2 - NS Record



```
→ dig luno.com NS

; <<>> DiG 9.20.15-2-Debian <<>> luno.com NS
;; global options: +cmd
;; Got answer:
;; ->HEADER<- opcode: QUERY, status: NOERROR, id: 16556
;; flags: qr rd; QUERY: 1, ANSWER: 2, AUTHORITY: 0, ADDITIONAL: 1
;; WARNING: recursion requested but not available

;; OPT PSEUDOSECTION:
; EDNS: version: 0, flags:; udp: 4096
;; QUESTION SECTION:
;luno.com.                IN      NS

;; ANSWER SECTION:
luno.com.                86398   IN      NS      barbara.ns.cloudflare.com.
luno.com.                86398   IN      NS      pablo.ns.cloudflare.com.

;; Query time: 1727 msec
;; SERVER: 192.168.110.1#53(192.168.110.1) (UDP)
;; WHEN: Wed Feb 25 12:13:20 WIB 2026
;; MSG SIZE rcvd: 93
```

Lampiran 4.3 - MX Record

```
(sofi@kali)-[~]
$ dig luno.com MX

; <<>> DiG 9.20.15-2-Debian <<>> luno.com MX
;; global options: +cmd
;; Got answer:
;; ->HEADER<- opcode: QUERY, status: NOERROR, id: 55548
;; flags: qr rd; QUERY: 1, ANSWER: 5, AUTHORITY: 0, ADDITIONAL: 1
;; WARNING: recursion requested but not available

;; OPT PSEUDOSECTION:
; EDNS: version: 0, flags:; udp: 4096
;; QUESTION SECTION:
;luno.com.                IN      MX

;; ANSWER SECTION:
luno.com.                300     IN      MX      1 aspmx.l.google.com.
luno.com.                300     IN      MX      10 aspmx2.googlemail.com.
luno.com.                300     IN      MX      10 aspmx3.googlemail.com.
luno.com.                300     IN      MX      5 alt1.aspmx.l.google.com.
luno.com.                300     IN      MX      5 alt2.aspmx.l.google.com.

;; Query time: 227 msec
;; SERVER: 192.168.110.1#53(192.168.110.1) (UDP)
;; WHEN: Wed Feb 25 12:13:48 WIB 2026
;; MSG SIZE rcvd: 167
```

Lampiran 4.4 - TXT Record



```
;; Transfer failed, retrying in 1000 msec.
; <<>> DiG 9.20.15-2-Debian <<>> luno.com TXT
;; global options: +cmd
;; Got answer:
;; ->HEADER<- opcode: QUERY, status: NOERROR, id: 47123
;; Flags: qr rd ra; QUERY: 1, ANSWER: 27, AUTHORITY: 0, ADDITIONAL: 1

;; OPT PSEUDOSECTION:
; EDNS: version: 0, flags:; udp: 512
;; QUESTION SECTION:
;luno.com.
IN TXT

;; ANSWER SECTION:
luno.com. 120 IN TXT "753733f9-6287-4b23-9d20-7ac1ad331fc4"
luno.com. 120 IN TXT "apple-domain-verification=GBVSV3Cjucyjkctv"
luno.com. 120 IN TXT "miro-verification=4788326ea986f9b16bd63bea8b9749c414910de3"
luno.com. 120 IN TXT "refrtaB-domain-verification=24727be351ba766e7c4d4b0ae7514088"
luno.com. 120 IN TXT "facebook-domain-verification=vaa-xj9lneindl9rrbxdtdpgpld985j"
luno.com. 120 IN TXT "slack-domain-verification=3NPD4QJTh3TDMMFv80c3ZLqS3LRQzux3KC34Ze9q"
luno.com. 120 IN TXT "canva-site-verification=0JJTwyY-q8z3PXMs2qp7zw"
luno.com. 120 IN TXT "atlassian-domain-verification=SylEcn/18z01eG6uzJXob8Gj5m/P9aaljWVTYDftLwaU3wTFXbaMAwL0E9McOxKH"
luno.com. 120 IN TXT "_globalsign-domain-verification=808QX_vjvZq26FfigKBNpdwC-H91ZKBCthOfQg91"
luno.com. 120 IN TXT "i0crl"Sk12WzRW6#fX8WBC7#b+6c755zRs4"ekw1xQGTayWbkyahHXqLBPcCohyesZ*RSUw+LcZQ$gK17^ZJLIU2oeV$ps41Hx"
luno.com. 120 IN TXT "MS=ms34207728"
luno.com. 120 IN TXT "Sendinblue-code=97fdfae4c9d85c75adfd567e7d4d8c89"
luno.com. 120 IN TXT "9WE8051D41ouVp/vZyixD3q1eNuZZAWdyBJkP39wquU="
luno.com. 120 IN TXT "google-site-verification=-3lyb59ufQ3ekgdj7KH7roH5ItplvYpeXv8Esfcc"
luno.com. 120 IN TXT "vzspfl include:amazones.com include:spf.google.com include:spf.atlassian.net include:spf.sendinblue.com include:mail.zendesk.com -all"
luno.com. 120 IN TXT "google-site-verification=oZHPk9qUPR8BuIDcp4FvEDf8K0SgrRDXx0_f81vzM-A"
luno.com. 120 IN TXT "atlassian-domain-verification=83oHBS/A1J64XX/TFrybxaW8IazPLVPhAJy6Ngd+JpryOYc8+OTBnQrFYQmSu0j"
luno.com. 120 IN TXT "9ea23da02c3b1de3f88d55b834c8f6d4623a39e3"
luno.com. 120 IN TXT "jamf-site-verification=DDvL3e2jyLX7qMMn82bqeA"
luno.com. 120 IN TXT "google-site-verification=L61gPMbLFz8hny9S02p7p4Np616uZ9Qx5I7uendPgt"
luno.com. 120 IN TXT "IvGqKLQjChgX0IRxc6Kka9xLMGeyELj9p1QILfivFys"
luno.com. 120 IN TXT "atlassian-sending-domain-verification=490b8116-0d1b-4089-813a-4e9814ac84d4"
luno.com. 120 IN TXT "twilio-domain-verification=5af0c6adf51ca8a9fe7454319d10b17f"
luno.com. 120 IN TXT "KKVru7CqxaU5D5AH-50JPY2BZ4Ulg"
luno.com. 120 IN TXT "google-site-verification=54vL31NVcPJ3A283GG3qNimU_5WV7IPcone6-3AAqLg"
luno.com. 120 IN TXT "0305SD46E6"
luno.com. 120 IN TXT "asv=436ee748f071776a95845238c6ff156d"

;; Query time: 327 msec
;; SERVER: 192.168.110.1#53(192.168.110.1) (TCP)
;; WHEN: Wed Feb 25 12:14:01 WIB 2026
;; MSG SIZE rcvd: 1966
```

Lampiran 4.5 - Zone Transfer (AXFR)

```
(sofi@kali)-[~]
$ dig axfr luno.com @barbara.ns.cloudflare.com

; <<>> DiG 9.20.15-2-Debian <<>> axfr luno.com @barbara.ns.cloudflare.com
;; global options: +cmd
; Transfer failed.

(sofi@kali)-[~]
$ dig axfr luno.com @pablo.ns.cloudflare.com

; <<>> DiG 9.20.15-2-Debian <<>> axfr luno.com @pablo.ns.cloudflare.com
;; global options: +cmd
; Transfer failed.
```

Lampiran 5 - Subdomain Enumeration



```
→ subfinder -d luno.com
```

```
subfinder
```

```
projectdiscovery.io
```

```
[INF] Current subfinder version v2.12.0 (latest)
[INF] Loading provider config from /home/sofi/.config/subfinder/provider-config.yaml
[INF] Enumerating subdomains for luno.com
sandbox.kubernetes.prod.luno.com
sites.luno.com
ws2.luno.com
app.luno.com
dev.staging.luno.com
fddkim.luno.com
mobileapi.staging.luno.com
ajax-geo.staging.luno.com
confluence.corp.luno.com
merchant.staging.luno.com
prometheus.prod.luno.com
transfer.corp.luno.com
unifi-controller.corp.luno.com
uob-jwt.luno.com
bz364.announcement.luno.com
eu-west-1.dev.luno.com
grafana-production.corp.luno.com
promos.luno.com
sw.luno.com
wificontroller.corp.luno.com
bouncer.corp.luno.com
movewith.luno.com
new2-www.luno.com
www.merchant.staging.luno.com
www.luno.com
ap-southeast-3.staging.luno.com
ethnio.luno.com
logsauth.prod.luno.com
sftp.luno.com
www.nebula.corp.luno.com
rundeck-staging.corp.luno.com
silvanarobinson.luno.com
staging-uob-jwt.luno.com
guide.luno.com
sandbox.luno.com
dev.luno.com
unifi-production.corp.luno.com
```



lunobase.corp.luno.com
www.staging.luno.com
uob.luno.com
voyager.corp.luno.com
grafana-staging.corp.luno.com
cloudflare-test.corp.luno.com
guide-staging.luno.com
staging-uob.luno.com
lunobase-staging.corp.luno.com
ntrust.dev.luno.com
preprod.kubernetes.prod.luno.com
promos.staging.luno.com
email.ethnio.luno.com
infosec.luno.com
ajax.staging.luno.com
kbounces.luno.com
librenms.corp.luno.com
papercut.corp.luno.com
corp.luno.com
status.corp.luno.com
crypto.luno.com
invest.luno.com
api.staging.luno.com
tipbot-46f120.luno.com
unifi-staging.corp.luno.com
treasury.luno.com
careers.luno.com
apollo.corp.luno.com
apollo-backend.corp.luno.com
test.luno.com
www.payments.luno.com
api.luno.com
ap-southeast-3.prod.luno.com
bz363.engage.luno.com
drive.luno.com
staging.luno.com
syncbugsnag-6c02ec.luno.com
www.alchemer.luno.com
o350.em.mailer.luno.com
staging.movewith.luno.com
alchemer.luno.com
link.mailer.luno.com
framer.staging.luno.com
monitoring.luno.com
trust.luno.com
console.luno.com
www.research.luno.com
staging.prod.luno.com
groups.luno.com



```
payment.luno.com
wordpress.prod.luno.com
mobileapi.luno.com
ajax-dns-lb.luno.com
artemis.corp.luno.com
zabbix.corp.luno.com
trade.staging.luno.com
trade.luno.com
ajax.luno.com
one.luno.com
status.luno.com
app.staging.luno.com
authproxy.prod.luno.com
grafana-ecs.corp.luno.com
reporting.indonesia.luno.com
build.luno.com
experiments.luno.com
framer.luno.com
o349.em.mailer.luno.com
indonesia.luno.com
api-geo.staging.luno.com
ws.luno.com
discover.luno.com
prod.luno.com
research.luno.com
dev-ntrust.luno.com
ntrust.luno.com
eu-west-1.staging.luno.com
confluence-staging.corp.luno.com
.luno.com
looker.corp.luno.com
careers-o2o.staging.luno.com
ws.staging.luno.com
ajax-id.luno.com
clicks.luno.com
houston.corp.luno.com
grafana.corp.luno.com
calendar.luno.com
nebula.corp.luno.com
new-www.luno.com
[INF] Found 129 subdomains for luno.com in 41 seconds 926 milliseconds
```

Lampiran 6.1 - Robots.txt

```
(sofi@kali)-[~]
$ curl https://www.luno.com/robots.txt
User-agent: *
Allow: /

Sitemap: https://www.luno.com/sitemap.xml
```

```
(sofi@kali)-[~]
$ curl https://www.staging.luno.com/robots.txt
User-agent: *
Allow: /

Sitemap: https://www.luno.com/sitemap.xml
```

Lampiran 6.2 - Sitemap.xml



```
sofi@kali:~$ wc -l params.txt
5937 params.txt

sofi@kali:~$ wc -l wayback.txt
42487 wayback.txt

sofi@kali:~$ grep -Ev "utm|fbclid|gclid|ref=source=campaign=" params.txt > clean1.txt

sofi@kali:~$ wc -l clean1.txt
5072 clean1.txt

sofi@kali:~$ grep -Ei "id=user=account=token=redirect=url=next=return=file=download=callback=email=reset=" clean1.txt > interesting.txt

sofi@kali:~$ wc -l interesting.txt
1038 interesting.txt

sofi@kali:~$ cat interesting.txt | sed 's/=[^&]*=/FUZZ/g' | sort -u > normalized.txt

sofi@kali:~$ wc -l normalized.txt
226 normalized.txt
```

Lampiran 7.3

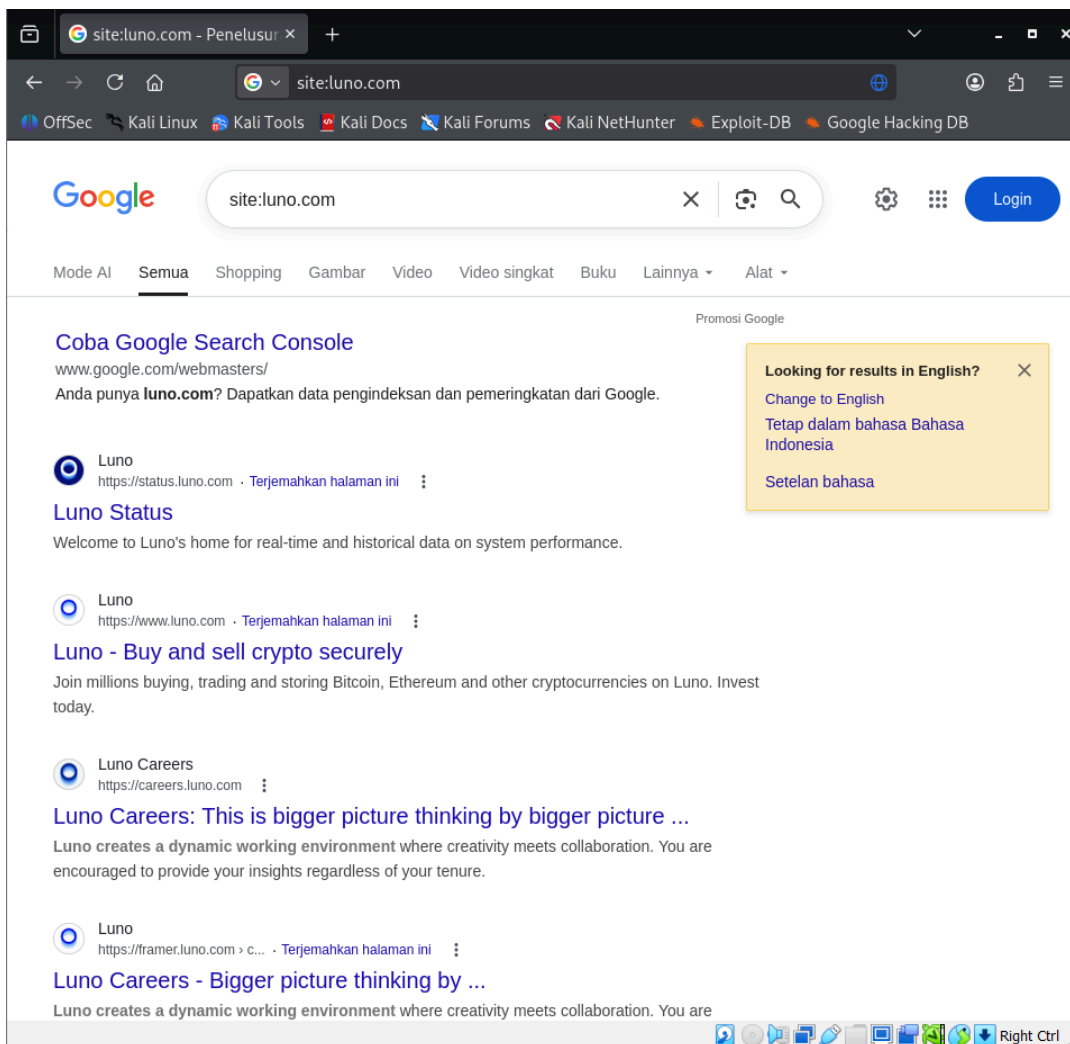
```
sofi@kali:~$ cat normalized.txt | cut -d'?' -f2 | cut -d'=' -f1 | sort | uniq -c | sort -nr
49 gh_jid
36 ticket_form_id
36 id
16 redirect
15 url
10 token
10 category_id
7 source_account_id
6 lid
4 irclickid
4 expires
3 state
2 tduid
2 target_account_id
2 referrer
2 login_token
2 language
2 email
1 type_id
1 tf_18482420570013
1 tf_18481130840989
1 tf_18463307295517
1 target_account_type
1 payment_id
1 mibextid
1 https://www.luno.com/8esheet
1 https://www.luno.com/en/8userId
1 https://www.luno.com/en/gb8userId
1 https://www.luno.com/en/8esheet
1 https://www.luno.com/en8esheet
1 https://www.luno.com/'data:image/svg+xml,%3Csvg%20xmlns
1 flow
1 domainname
1 code
1 brand_id
1 account_id
```



Lampiran 7.4

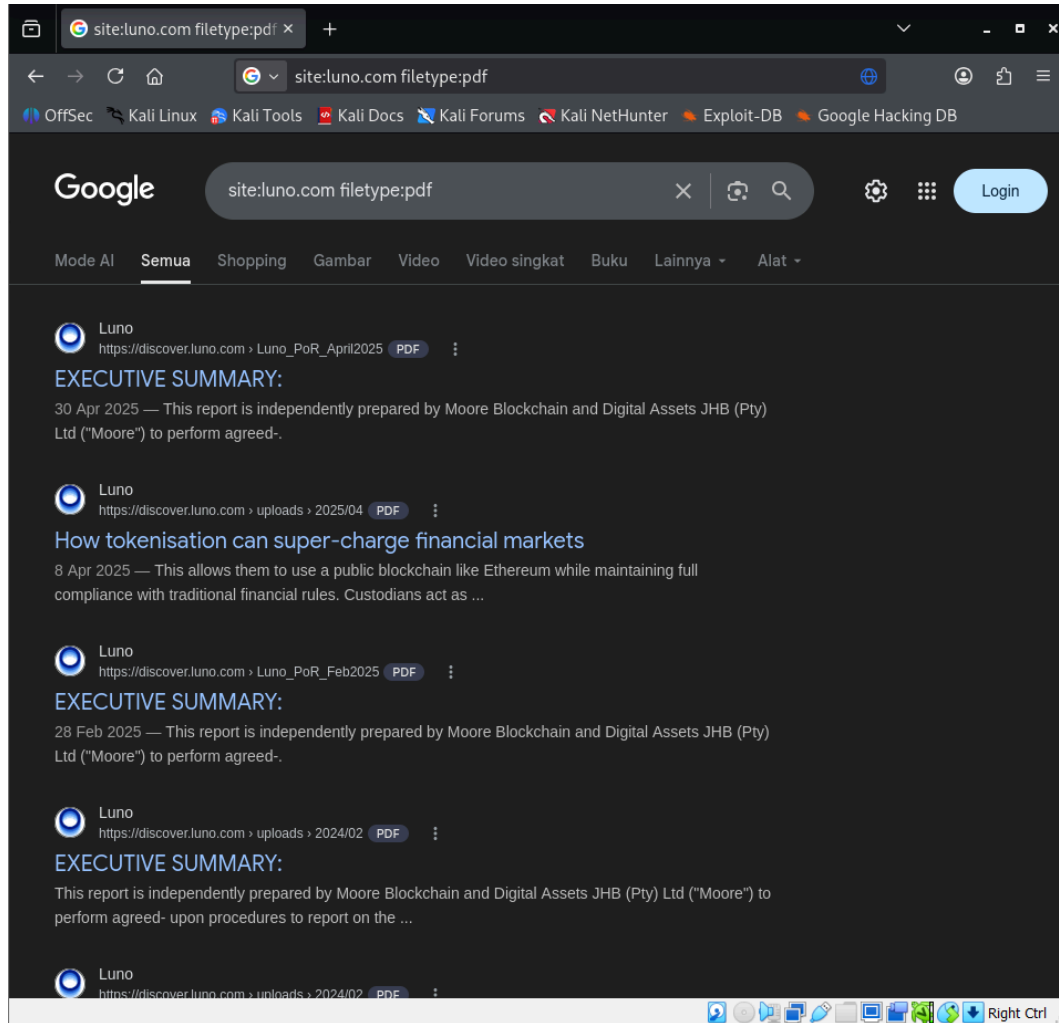
```
(sofi@kali)-[~]  
$ cut -d'?' -f1 normalized.txt | sort | uniq -c | sort -nr | head  
15 https://guide.luno.com/hc/en-gb/requests/new  
9 https://guide.luno.com/hc/ms-my/requests/new  
9 https://guide.luno.com/hc/id/requests/new  
6 https://guide.luno.com/hc/fr/requests/new  
4 https://www.luno.com/wallet/transfer  
3 https://www.luno.com/wallet/buy  
3 https://www.luno.com/help/en/tickets/new  
3 https://www.luno.com/  
2 https://www.luno.com/wallet/beneficiaries/add  
2 https://www.luno.com/signup
```

Lampiran 8.1 - Subdomain yang Terindeks



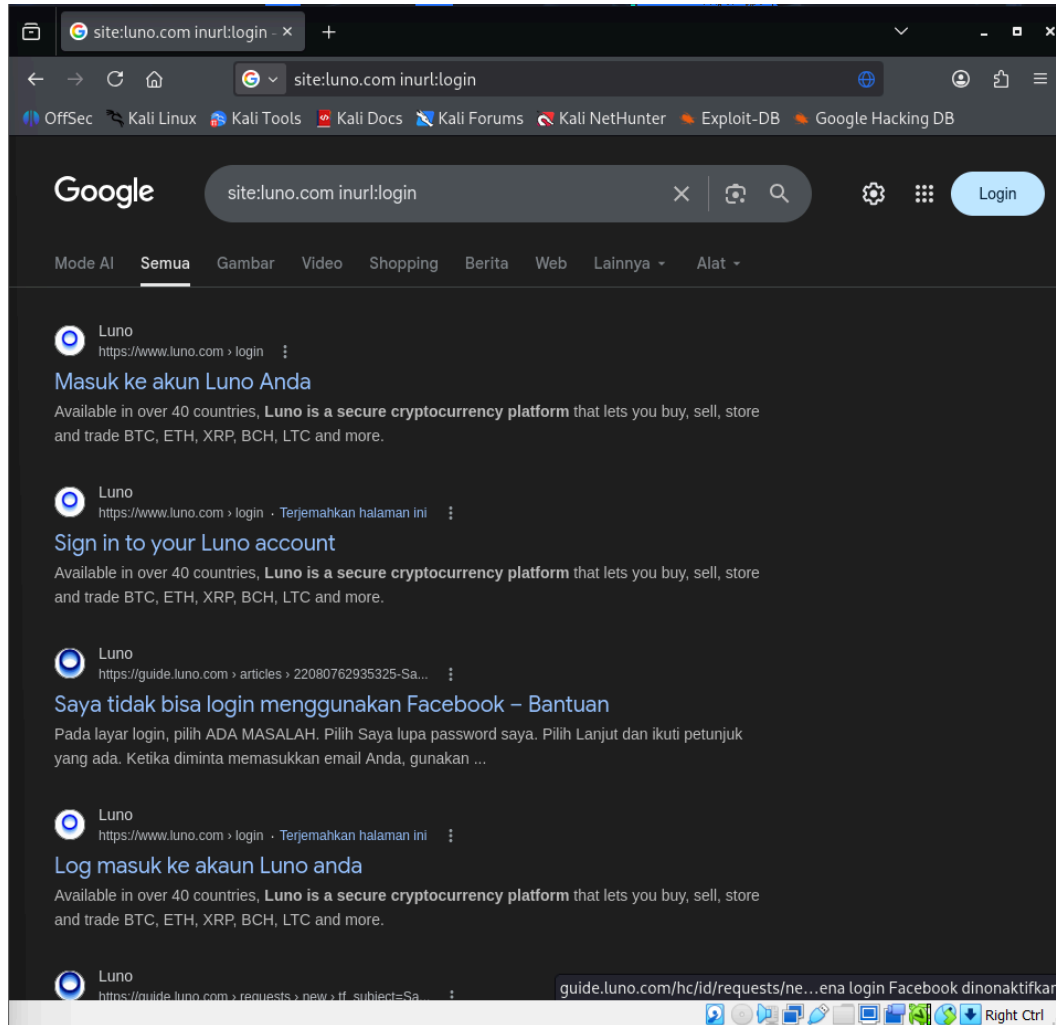


Lampiran 8.2 - File Sensitif



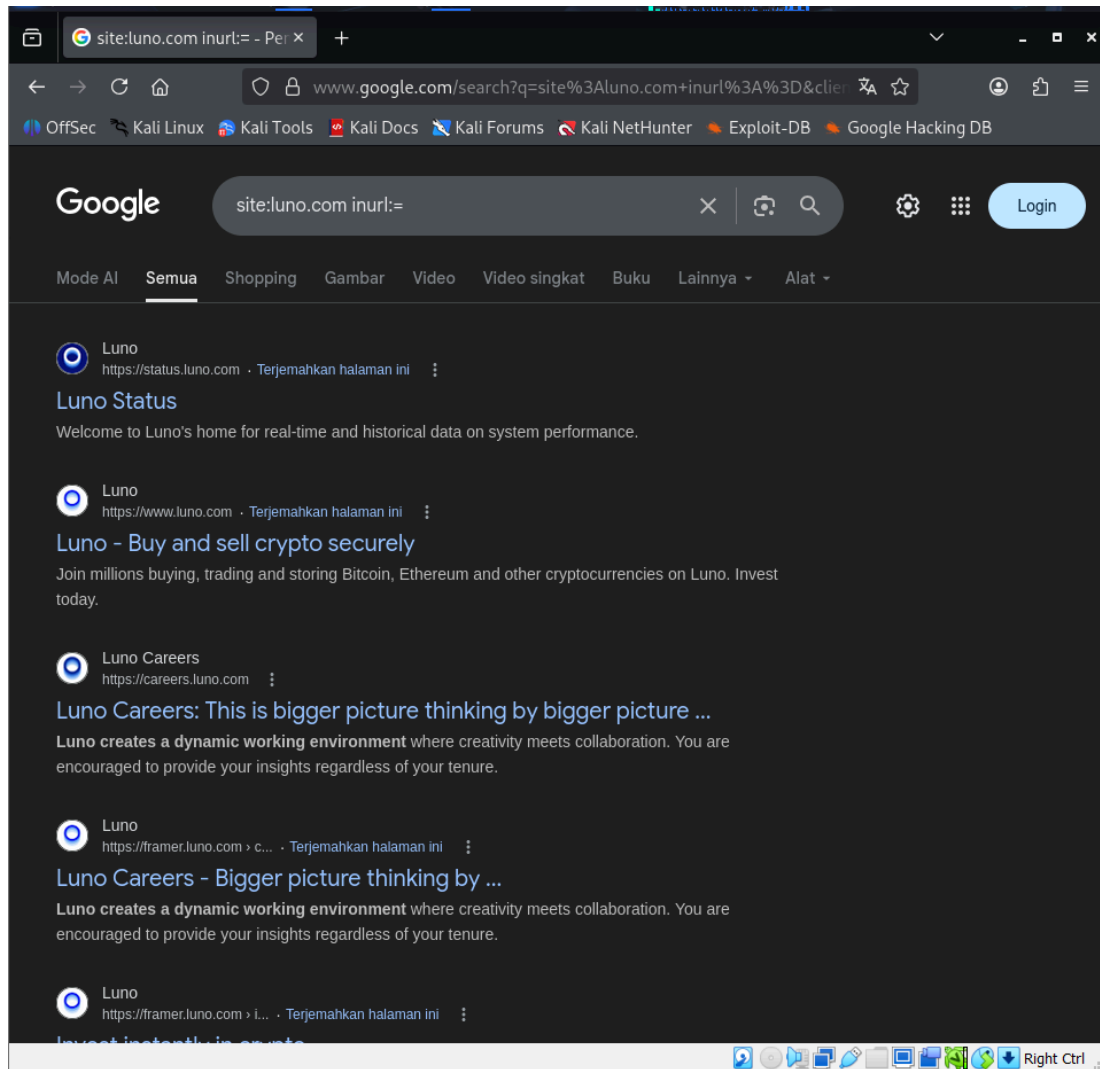


Lampiran 8.3 - Halaman Login



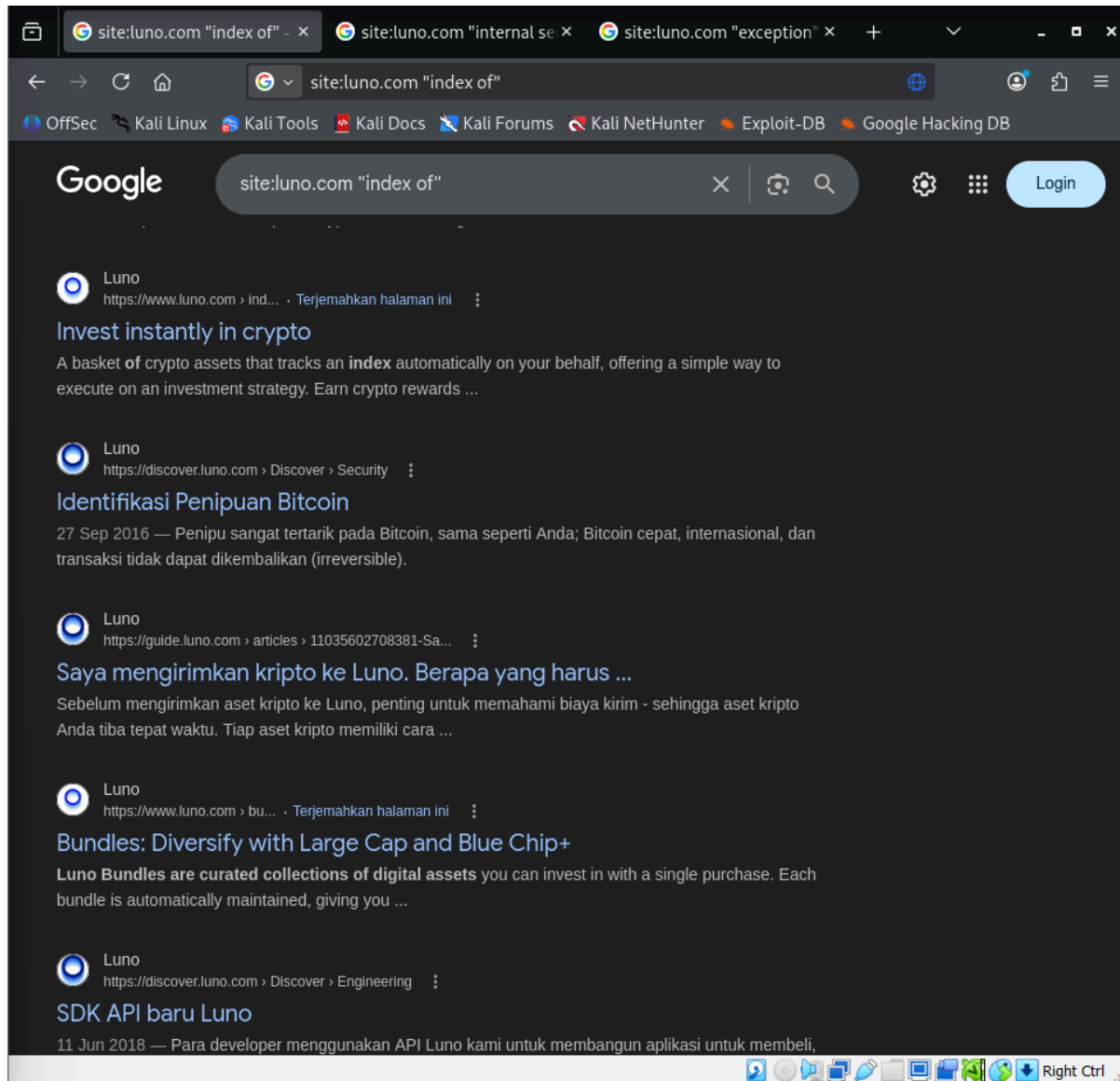


Lampiran 8.4 - Parameter Terindeks





Lampiran 8.5 - Error / Debug Page





Lampiran 8.6 - API Exposure

